情報処理安全確保支援士試験　科目A-2　中分類23 情報セキュリティの脅威　#02

攻撃の流れと認証への攻撃

攻撃者はどんな順で動くのか。パスワードとセッションはどう狙われるのか

各ページの下に、根拠にした資料（IPA の支援士試験シラバス案・安全なウェブサイトの作り方、Lockheed Martin、MITRE ATT&CK など）を書いた。過去問は IPA 公開の午前 II 。例の会社や場面は Claude が作った

全体像 シラバス案 中分類23 小分類2「攻撃手法」のうち前半

1 攻撃のライフサイクルとフレームワーク
サイバーキルチェーン・MITRE ATT&CK（TTP）・偵察・初期侵入・権限昇格・永続化・横展開・C2・持ち出し

2 パスワードと資格情報への攻撃
総当たり・辞書・リバース・スプレー・クレデンシャルスタッフィング・レインボーテーブル・Pass the Hash・MFA 疲労

3 セッションと通信への攻撃
セッションハイジャック・固定化・リプレイ・中間者・MITB とトランザクション署名

この分野の過去問（令和元〜7年度）

テーマ	出た回
Pass the Hash	R3秋・R5春・R7秋
MITB とトランザクション署名	H31春・R2・R4春・R5秋
サイバーキルチェーン	R3秋・R4春
パスワードスプレー・総数の式	R4秋・R4春
MITRE ATT&CK・ドメインフロンティング	R6秋・R7秋

同じ問題が何度も出るのが午前 II の特徴。Pass the Hash は3回とも同じ選択肢。

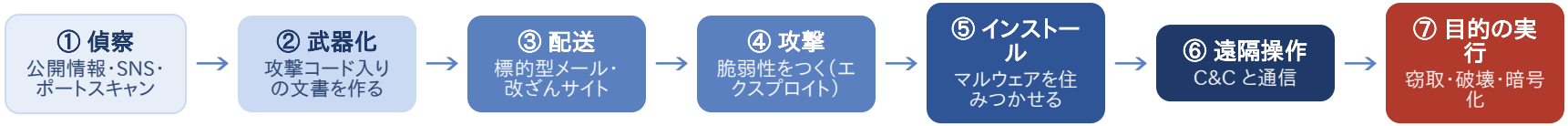
出典：IPA「支援士試験 シラバス（案）」中分類23 小分類2／IPA 午前 II 各回（このPDFの問題演習を参照）

第1章

攻撃のライフサイクルとフレームワーク

攻撃を「段階」で見るのがキルチェーン、「手口の辞書」として見るのが
ATT&CK。

サイバーキルチェーン：7つの段階のどこかで鎖を断つ



段階	断つ対策の例
①	公開する情報を絞る（攻撃対象領域の最小化）
③	メールの添付・URL の検査、送信ドメイン認証、訓練
④⑤	パッチ、マクロの無効化、EDR
⑥	外向き通信の制限・監視（コネクトバック対策）
⑦	アクセス権の最小化、DLP、バックアップ

R4春 問5 のひっかけ：「インターネットに公開されていない社内ポータルから組織図を入手」は、もう侵入したあと（偵察ではない）。偵察は**侵入する前に外から**集める。

R3秋 問5：「チェーン」の言葉から、サプライチェーン・中間者攻撃・ブロックチェーンの説明を並べてくる。

出典：Lockheed Martin「Cyber Kill Chain」（7段階）／IPA 午前 II　令和4年度春期 問5・令和3年度秋期 問5。日本語の段階名は Claude の訳

MITRE ATT&CK：実際の攻撃の手口を集めた辞書

Enterprise 版の14の戦術（攻撃者の目的）

偵察	リソース開発	初期アクセス	実行
永続化	権限昇格	防御回避	認証情報アクセス
探索	**横展開**	収集	C&C
持ち出し	影響		

TTP の3つの階層

戦術（Tactics）
何のために：例）認証情報アクセス

技術（Techniques）
どうやって：例）OS の認証情報のダンプ

手順（Procedures）
具体的に：例）あるツールでメモリからハッシュ値を取り出す

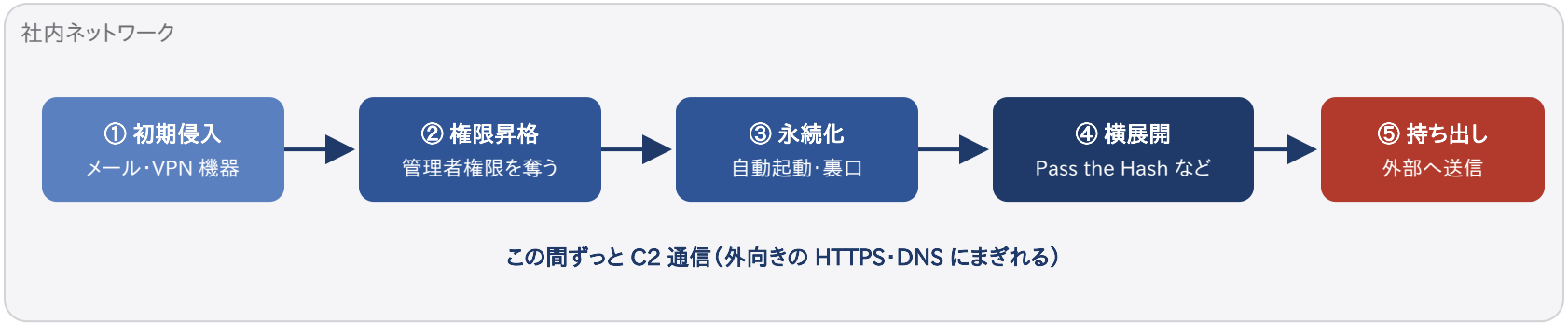
R6秋 問3 の選択肢の正体

名前	正体
MITRE ATT&CK	**攻撃手法を分類したナレッジベース**（正解）
CVSS	脆弱性の深刻度の評価方法（#19）
STIX／TAXII	脅威情報の記述形式／交換手順（#09）
キルチェーン	攻撃の7段階のモデル

> **なぜ TTP か：**IP アドレスやハッシュ値（IoC）は攻撃者がすぐ変えられる。行動のくせ（TTP）は変えにくいので、TTP に基づく検知は長く効く。

出典：MITRE「ATT&CK Enterprise Tactics」／IPA 午前 II 令和6年度秋期 問3。日本語の戦術名は Claude の訳

侵入してから目的を果たすまで



ドメインフロンティング（R7秋 問8）：CDN を通るとき、外から見える接続先（TLS の SNI）は有名な正規ドメイン、暗号化された中身（HTTP の Host ヘッダ）は攻撃者のサーバ。URL フィルタでは止めにくい C2 の隠し方。

R7秋 問8 のひっかけ：偽の DNS 情報を蓄積させる＝DNS キャッシュポイズニング、送信元を偽装した DNS 要求＝DNS リフレクション、ドメイン情報の書換え＝ドメイン名ハイジャック（#04）。

出典：IPA「支援士試験 シラバス（案）」用語例「初期侵入，権限昇格，永続化，ラテラルムーブメント，C2，持ち出し（Exfiltration）」／IPA 午前 II 令和7年度秋期 問8

第2章

パスワードと資格情報への攻撃

「何を固定して、何を変えるか」で見分ける。ハッシュ値は解読しなくても使われることがある。

パスワードを当てる攻撃：何を固定し、何を変えるか

攻撃	固定	変えて試す	ロックは効く？
ブルートフォース	1つの ID	すべての文字の組合せ	**効く**
辞書攻撃	1つの ID	辞書の単語・人名・その組合せ	**効く**
リバースブルートフォース	1つのパスワード	多数の ID	**効かない（各 ID は1回）**
パスワードスプレー	よく使われるパスワード	多数の ID に、時刻と接続元 IP を変えて少しずつ	**回避される**
クレデンシャルスタッフィング	漏れた ID とパスワードの組	別のサイトで試す	**失敗が少なく気付きにくい**

R4春 問4 文字の種類 M、文字数 n のパスワードの総数は M^n（同じ文字を何度使ってもよく、順番も区別する）。
M!/(M−n)! は「同じ文字を使わない並べ方」、M!/(n!(M−n)!) は「組合せ」なので誤り。

共通の切り札は MFA。加えて、スプレーやリバースは「1つの ID の失敗回数」では見えないので、**組織全体のログイン失敗の傾向**や接続元を監視する。スタッフィングは使い回しの禁止と、漏えいしたパスワードの利用の拒否。

出典：IPA 午前 II 令和4年度秋期 問6（パスワードスプレー）・令和4年度春期 問4（総数の式）／IPA「支援士試験 シラバス（案）」用語例「ブルートフォース攻撃, リバースブルートフォース攻撃, クレデンシャルスタッフィング」

ハッシュ値をねらう攻撃：解読するか、そのまま使うか

レインボーテーブル攻撃（解読する）

盗んだハッシュ値 → 事前計算した表（ハッシュ → 平文） → 平文パスワード

対策：ソルト（利用者ごとの乱数）
同じパスワードでもハッシュ値が変わり、表が使えない

Pass the Hash（解読しない）

メモリから盗んだハッシュ値 → そのまま送る → ファイルサーバ NTLM 認証

ハッシュ値だけで認証できるしくみの悪用
横展開の定番。Kerberos のチケット版が Pass the Ticket

R7秋 問2（R5春・R3秋と同じ） 「ハッシュ値から導出された平文パスワードを使う」は**解読してから使う**ので Pass the Hash ではない。正解は「パスワードのハッシュ値だけでログインできる仕組みを悪用してログインする」。

Pass the Hash の対策：管理者アカウントを端末ごとに分ける（同じパスワードの使い回しをしない）、特権アカウントの利用を絞る（PAM）、メモリからの認証情報の窃取を防ぐ OS の機能、NTLM より強い認証方式に移す。

出典：IPA 午前 II 令和7年度秋期 問2／IPA「支援士試験 シラバス（案）」用語例「レインボーテーブル攻撃」、中分類26「パスワードクラック対策（ソルト，ストレッチング など）」

多要素認証をすり抜ける攻撃

MFA 疲労攻撃（プッシュ通知爆撃）

1. 攻撃者は ID とパスワードをすでに持っている
2. ログインを何度も試し、承認の通知を大量に送る
3. 利用者が根負けや誤操作で「承認」を押す

対策：番号照合（ログイン画面の数字を入力させる）、通知に地域やアプリ名を表示、短時間の繰り返しを制限、パスキーへの移行。

AiTM フィッシング（中継型）



ワンタイムコードは中継されると防げない。パスキー（FIDO2）はブラウザが接続先のオリジンを確かめて署名するので、偽ドメインでは成り立たない＝**フィッシング耐性**（#10）。

ひっかけ：「パスワードを長くする」「有効期限を短くする」は、攻撃者がすでにパスワードを持っている／その場で中継している攻撃には効かない。

出典：IPA「支援士試験 シラバス（案）」用語例「MFA 疲労攻撃（…プッシュ通知爆撃（Push Bombing））」、中分類25「フィッシング耐性のある認証」「FIDO（FIDO2, WebAuthn, CTAP, パスキー）」

第3章

セッションと通信への攻撃

ログインのあとは「セッション ID」が本人の証明になる。そこと、通信の途中が狙われる。

セッションハイジャックとセッション固定化

セッションハイジャック（あとから盗む）	
盗まれ方	**対策**
推測（連番・時刻）	暗号論的な乱数で十分長い ID
盗聴	HTTPS、cookie の Secure 属性
XSS で cookie を読む	XSS 対策、HttpOnly 属性
URL に埋め込んだ ID の漏えい	ID は cookie で受け渡す

セッション固定化（先に渡しておく）

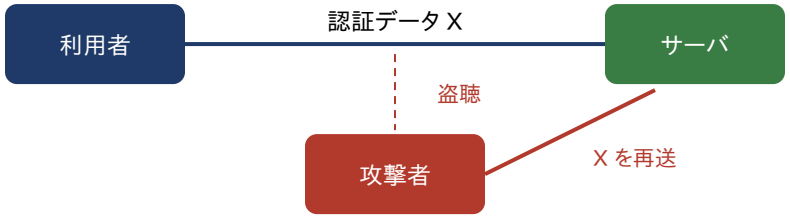
1. 攻撃者がサイトから正規のセッション ID を手に入れる
2. その ID を利用者に使わせる（細工したリンクなど）
3. 利用者がその ID のままログインする
4. 攻撃者が同じ ID で、ログイン済みとして入る

対策：ログインに成功したら新しい ID を発行し、古い ID を無効にする。ID を URL で受け渡さない。

出典：IPA「安全なウェブサイトの作り方」（セッション管理の不備）／IPA「支援士試験 シラバス（案）」用語例「セッションハイジャック，セッション固定化攻撃（Session Fixation），リプレイ攻撃」

リプレイ攻撃と中間者攻撃

リプレイ攻撃：盗聴したものを再送する



対策：毎回変わる値を混ぜる。チャレンジレスポンス、ナンス、タイムスタンプ、シーケンス番号、ワンタイムパスワード。「毎回同じハッシュ値を送る」は再送されれば通る。

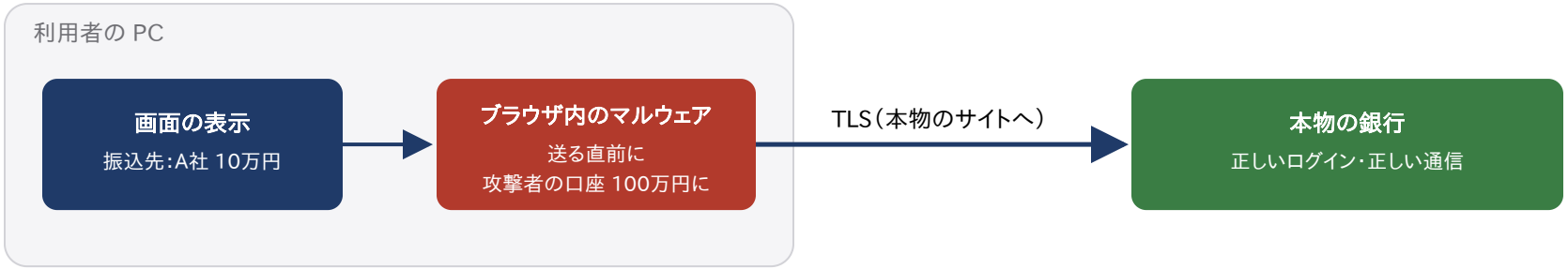
中間者攻撃（MITM）：間に入り込む

入り込み方	防ぎ方
偽の Wi-Fi アクセスポイント	TLS とサーバ証明書の検証
ARP スプーフィング	DHCP スヌーピング・動的 ARP 検査（#13）
DNS の偽の応答	DNSSEC（#14）
HTTPS を HTTP に下げる	HSTS（#17）

証明書の**警告を無視**して接続すると、TLS を使っていても中間者攻撃は防げない。

出典：IPA「支援士試験 シラバス（案）」用語例「リプレイ攻撃」／中分類25「TLS」「DHCP スヌーピング」、中分類26「HSTS」

MITB 攻撃:ブラウザの中で取引を書き換える



対策(R4春 問11 の選択肢)	効く?	理由
EV SSL サーバ証明書で接続先を確認	×	接続先は本物の銀行
ログインのワンタイムパスワード	×	ログインは本人が正しく行う。書き換えはログイン後
SSL ではなく TLS で暗号化	×	書き換えは暗号化の前(ブラウザの中)
トランザクション署名	○	取引内容そのものを、PC と別の機器で検証する

出典:IPA 午前 II 令和4年度春期 問11(令和2年度10月 問10)。図の口座や金額は Claude が作った例

トランザクション署名のしくみ

1. **別の機器で計算:** ハードウェアトークン(またはスマホ)に振込先口座番号と金額を入力し、MAC を作る
2. **送る:** 振込画面に振込先・金額・MAC を入力して銀行に送る
3. **銀行で計算:** 受け取った振込先・金額から、同じ手順で MAC を作る
4. **照合:** ②の MAC と③の MAC が一致すれば、振込先と金額は**改ざんされていない**

H31春 問8 ④でできるのは「振込先口座番号と振込金額が改ざんされていないことを確認できる」。
盗聴されていないこと・盗聴者の特定・改ざん箇所の訂正は、MAC ではできない。

R5秋 問7 トランザクション署名=「送金操作を行う PC とは別のデバイスに振込先口座番号などの取引情報を入力して表示された値」を送る。
取引内容に結び付かないワンタイムパスワード(メール・ログイン用)は誤り。

2つの条件: ①PC とは別の機器で計算する(PC のマルウェアが触れない)、②取引の内容(振込先・金額)を入力して計算する。どちらが欠けても MITB は防げない。MAC のしくみは #16。

出典:IPA 午前 II 平成31年度春期 問8・令和5年度秋期 問7

試験で狙われやすい比較10選

比べるもの	見分けるポイント
キルチェーン ⇔ ATT&CK	7つの段階のモデル ⇔ 戦術・技術・手順のナレッジベース
偵察 ⇔ 目的の実行	侵入前に外の公開情報を集める ⇔ 侵入後に社内の情報を集める
配送 ⇔ 攻撃（エクスプロイト）	メールなどで届ける ⇔ 脆弱性をついて動かす
ブルートフォース ⇔ リバース	ID 固定でパスワードを変える ⇔ パスワード固定で ID を変える
リバース ⇔ スプレー	スプレーは時刻と接続元も変えてロックと検知を避ける
辞書攻撃 ⇔ スタッフィング	よくある単語を試す ⇔ 他サイトで漏れた正しい組を試す
レインボーテーブル ⇔ Pass the Hash	ハッシュ値を解読する ⇔ 解読せずそのまま使う
ハイジャック ⇔ 固定化	あとから盗む ⇔ 先に渡しておく（対策はログイン時の ID の再発行）
中間者攻撃 ⇔ MITB	通信路の途中 ⇔ ブラウザの中（TLS も証明書も効かない）
ワンタイムパスワード ⇔ トランザクション署名	「だれか」を確かめる ⇔ 「取引の内容」を確かめる

次の #03 では、Web アプリケーションの不備をねらう攻撃（SQL インジェクション・XSS・CSRF など）を扱う。

出典：このPDFの各ページの資料